PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurité opérationnelle et bonnes pratiques

09-430 PSE-ER F4-8 Bonnes pratiques de sécurité opérationnelle — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. En cas d'intrusion, déconnectez l'équipement du réseau sans l'éteindre ni le redémarrer.
2. La force d'un mot de passe repose sur sa longueur et la diversité de ses caractères.
3. La journalisation est un moyen de détection et d'analyse qui ne remplace pas les mécanismes de protection.

Synthèse des bonnes pratiques en cas d'intrusion

Notion	À retenir
Détection intrusion	Utiliser outils **host-based** (journaux) et **network-based** (trafic). Surveiller : fichiers disparus, connexions inhabituelles, services non autorisés, modification du fichier de mots de passe ou création de comptes.
Détection/Suspicion	Déconnecter du réseau **sans éteindre ni redémarrer**. Prévenir responsable sécurité et hiérarchie (téléphone/vive voix). Prévenir le **CERT** (ou **CERTA** pour les administrations).
Après - Étapes 1	Faire une copie physique de bas niveau (ex: `dd` sous Unix) incluant secteurs non occupés. Copier, dater et signer numériquement les traces des autres équipements. **Ne pas contacter l'attaquant**.
Après - Suite	Réinstaller le système depuis une **version saine**. Appliquer correctifs, tester avec un scanner (ex: **Nessus**), supprimer services inutiles et changer **tous les mots de passe**.
Après - Fin/Légal	Lister les manques pour améliorer protection et procédures. Seule la **direction** peut porter plainte. Services : **OCLCTIC**, **BEFTI**, **DCRI** (sûreté de l'État).

Synthèse de la gestion des mots de passe

Notion	À retenir
Attaques de mot de passe	Force brute (toutes combinaisons), dictionnaire (mots/règles de transformation), compromis temps-mémoire (hachage/réduction, efficace sur **hash LM**), chaînes de Markov, et attaques indirectes (filoutage, enregistreur de frappe).
Un bon mot de passe	Fort (longueur et mélange **minuscules, majuscules, caractères spéciaux, chiffres**) et facile à retenir via **méthodes mnémotechniques** (phonétique ou premières lettres d'une phrase).
Politique de gestion	Intégrer sensibilisation, canal sûr pour mot de passe initial, critères techniques (longueur, historique **n** derniers, verrouillage) et privilégier **certificat/clé privée** sur carte à puce qualifiée **ANSSI**.
Recommandations ANSSI	Mots de passe distincts, sans lien avec l'identité, jamais créés par un tiers, pas de mot de passe par défaut, renouvellement tous les **90 jours** (données sensibles), pas de stockage exposé, pas d'envoi sur messagerie personnelle, rien retenu par le navigateur.

Synthèse des attaques DDoS

Notion	À retenir
Contexte et enjeux	Attaque rendant un service indisponible par saturation de **bande passante** (**volumétrique**) ou épuisement de **ressources** (sessions **TCP**, bases de données).
Typologie des attaques	**Réflexion** (IP de la victime usurpée, réponses de serveurs réflecteurs) et **amplification** (réponse bien plus volumineuse : **DNS**, **NTP**, **SNMP**, **SSDP**), souvent UDP ; **botnets** loués (**booter**, **stresser**).
Protections techniques	En bordure : pare-feu/répartiteurs (trafic faible) ; **pas de suivi de connexions entrantes** devant un serveur à forte audience. Opérateur : filtrage ou **blackholing** (protège l'infrastructure mais rend le déni effectif).
Protections organisationnelles et pratiques	Segmentation : isoler sous-réseaux/serveurs via réseau d'administration dédié ou **QoS** de priorisation.

Synthèse de la journalisation

Notion	À retenir
Rôle et pré-requis	Moyen de **détection** et d'**analyse** (non substitut de la protection). Pré-requis : **horodatage** activé, **horloges synchronisées** sur sources externes fiables, stockage dimensionné.
Architecture	Export automatique vers **serveurs centraux dédiés** et redondés. Transfert **temps réel** via **TCP** de préférence. Utiliser une **partition disque dédiée** et une **rotation journalière**.
Aspects juridiques	L'**intégrité** et la **valeur probatoire** passent par la **signature** et l'**horodatage**. Les **FAI/hébergeurs** conservent les journaux **au minimum un an**. Associer les personnels à la définition des processus.

Sécurisation d'un système Linux

Notion	À retenir
Réduire la surface d'attaque	Supprimer les éléments logiciels superflus (couche utilisateur, noyau, modules). Éliminer les services inutiles en écoute, les services sous **root** non nécessaires, le **serveur X**, les compilateurs ou débogueurs.
Défense en profondeur	Multiplier les barrières : ajouter un **pare-feu local** et partitionner rationnellement les répertoires remplis de l'extérieur (**journaux**, file d'impression, etc.) avec options `ro`, `nodev`, `noexec`, `nosuid`.
Recommandations ANSSI	Mises à jour, suppression logiciels inutiles, `netstat` pour inventaire, limiter services par interface, désactiver modules via `sysctl`, moindre privilège (**AppArmor**, **grsecurity**), cloisonnement (**lxc**, **openvz**) et journalisation cohérente.

Comparatif SRP et AppLocker

Notion	À retenir
Des SRP à AppLocker	Les **SRP** utilisent une liste blanche mais touchent **tous les utilisateurs** ; **AppLocker** permet de cibler un **utilisateur précis** (machine ou domaine).
Stratégie AppLocker	Sans inventaire exhaustif : **mode audit** pour repérer les applications inconnues. Service `AppIdSvc` en **démarrage automatique**. Utilisateurs en **compte standard**.
Les limites d'AppLocker	Ne contrôle pas le **comportement** d'un programme lancé, ni les **applications 16 bits** (via `NTVDM`), ni tous les **codes interprétés** (Perl, macros).

Pièges et confusions

- ⚠ Contacter l'attaquant soi-même en cas d'intrusion.
- ⚠ Éteindre ou redémarrer une machine compromise.
- ⚠ Stocker la copie physique du disque sur le disque à étudier.
- ⚠ Supprimer uniquement la vulnérabilité exploitée sans réinstaller entièrement le système.
- ⚠ Seul l'utilisateur peut déposer plainte (c'est la direction de l'organisme).
- ⚠ Activer le suivi de connexions sur un pare-feu devant un serveur à forte audience.

Sigles et définitions

CERT	Autorité de veille publiant avis et alertes sur les failles.
DDoS	Déni de service faisant intervenir un réseau de machines souvent compromises.
Blackholing	Mesure d'un opérateur consistant à router vers le néant tout le trafic destiné à la victime.
AppLocker	Évolution des SRP permettant de cibler un utilisateur ou un groupe précis.
NTVDM	Processus exécutant les applications 16 bits, non contrôlées par AppLocker.
Valeur probatoire	Force juridique d'un élément de preuve.

Auto-test

1. Quelle commande permet de réaliser une copie physique de disque sous Unix ?
2. Quel service doit être démarré automatiquement pour activer AppLocker ?
3. Quelle est la durée minimale de conservation des journaux par les FAI et hébergeurs ?
4. Quelle méthode statistique optimise les attaques de mot de passe ?
5. Quel service est l'évolution des SRP pour cibler un utilisateur précis ?

Réponses : **1.** dd · **2.** AppIdSvc · **3.** un an · **4.** Chaîne de Markov · **5.** AppLocker

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.